

PROJECT REPORT

OJT PROJECT



FPT UNIVERSITY

**FACULTY OF INFORMATION TECHNOLOGY
INFORMATION ASSURANCE**

Mentor: Pham Ngoc Chanh



Can Tho, August 2026

DANH SÁCH THÀNH VIÊN

Họ và tên	Mã số sinh viên	Vai trò
Đinh Đăng Khoa	CE190369	Leader
Hứa Hồ Nhân Nghĩa	CE190490	Member
Nguyễn Võ Quốc Thái	CE190072	Member
Bùi Đức Trọng	CE191346	Member

TÓM TẮT

Dự án xây dựng một nền tảng giám sát và vận hành an toàn thông tin theo mô hình SOC thu gọn, lấy Wazuh làm lõi SIEM, OpenSearch làm tầng lưu trữ – truy vấn, đồng thời tích hợp Threat Intelligence, quản lý sự cố, tự động phản ứng và các chức năng AI hỗ trợ phân tích. Mục tiêu chính là hình thành một chu trình khép kín từ thu thập telemetry, phát hiện, làm giàu ngữ cảnh, phân loại, mở case, cảnh báo đa kênh đến thực thi phản ứng có kiểm soát.

Hệ thống được triển khai trên mô hình lab phân tán với các node riêng cho Manager, Indexer, Dashboard và cụm công cụ hỗ trợ. Nguồn dữ liệu bao gồm endpoint Windows/Linux, FIM, Sysmon, Sysmon for Linux, thiết bị mạng qua Syslog và ứng dụng OWASP Juice Shop đặt sau ModSecurity WAF. Các luật tùy chỉnh được ánh xạ MITRE ATT&CK, kết hợp IOC từ MISP và các dịch vụ uy tín IP/hash. Luồng vận hành sử dụng TheHive/Cortex cho case management và phân tích observable, Telegram cho cảnh báo/ChatOps, cùng Active Response để block hoặc quarantine khi được phê duyệt.

Tại thời điểm bàn giao, lõi SIEM, thu thập endpoint, Threat Intelligence, IOC correlation, TheHive/MISP và các luồng phản ứng cơ bản đã vận hành. Các hạng mục chưa đạt mức production gồm NL2Query mới đạt khoảng 60% độ phù hợp ngữ nghĩa, Dynamic Playbook và Gap Analysis chưa hoàn thiện, Network Dashboard còn tinh chỉnh, duplicate alert chưa được loại bỏ hoàn toàn và false positive rate vẫn ở mức 15–20%, cao hơn mục tiêu dưới 10%. Báo cáo vì vậy trình bày cả năng lực đã đạt được lẫn giới hạn còn tồn tại để đơn vị tiếp nhận có thể vận hành và phát triển tiếp một cách thực tế.

KẾT QUẢ CỦA ĐỀ TÀI

Chỉ số	Giá trị	Ý nghĩa vận hành
MITRE ATT&CK coverage	21 Technique ID / 11 Tactic	Cho phép phân loại cảnh báo theo hành vi và hỗ trợ threat hunting.
IOC trong MISP/CDB	1.904 IOC	Đã kiểm thử đối sánh IP/domain/hash và sinh alert.
SOC drill	12.527 alert hits	Mô phỏng tải cảnh báo lớn trong thời gian kiểm thử.
True Positive được triage	5 sự cố tiêu biểu	Tập trung vào brute force và FIM trong đợt drill được ghi nhận.
MTTD/Triage	Dưới 3 phút	Từ log thô đến phân loại và quyết định escalate trong bài kiểm thử.
False Positive Rate	15–20%	Đã giảm nhưng chưa đạt mục tiêu dưới 10%.
AI JSON validity	100% theo đợt kiểm thử	Có post-processing, retry và fallback để tránh crash do JSON malformed/null.
NL2Query semantic accuracy	Khoảng 60%	End-to-end đã có nhưng chưa đủ ổn định để dùng như công cụ điều tra chính.

MỤC LỤC

Nội dung	Trang
1. Tổng quan giải pháp	5
2. Kiến trúc và luồng dữ liệu	8
3. Nền tảng và baseline triển khai	11
4. Detection Engineering và MITRE ATT&CK	15
5. Threat Intelligence, Case Management và phản ứng	18
6. AI, ChatOps (NL2Query)	20
7. Dashboard, SOC Workflow và Playbook	23
8. Kiểm thử và đánh giá	25
9. Vận hành và bàn giao kỹ thuật	27
10. Kết luận	29
Phụ lục A. MITRE ATT&CK Mapping	30
Phụ lục B. Ma trận port và dịch vụ	33
Phụ lục C. Các lệnh xác minh bàn giao	34

DANH MỤC TỪ VIẾT TẮT

Từ viết tắt	Diễn giải
SIEM	Security Information and Event Management
SOC	Security Operations Center
SOAR	Security Orchestration, Automation and Response
IOC	Indicator of Compromise
FIM	File Integrity Monitoring
EDR	Endpoint Detection and Response
MTTD	Mean Time to Detect
MTTR	Mean Time to Respond

Từ viết tắt	Diễn giải
MITRE ATT&CK	Khung phân loại chiến thuật và kỹ thuật tấn công
WAF	Web Application Firewall
LLM	Large Language Model
DSL	Domain Specific Language / OpenSearch Query DSL
TI	Threat Intelligence
FPR	False Positive Rate
TLS	Transport Layer Security
ILM	Index Lifecycle Management

1. TỔNG QUAN GIẢI PHÁP

1.1. Bối cảnh và bài toán cần giải quyết

Các hệ thống truyền thống thường thu thập nhiều log nhưng thiếu khả năng liên kết sự kiện, làm giàu ngữ cảnh và phản ứng nhanh. Trong môi trường có nguồn lực SOC hạn chế, analyst dễ bị quá tải bởi cảnh báo lặp, khó xác định ưu tiên, đồng thời phải chuyển đổi thủ công giữa dashboard, dịch vụ Threat Intelligence, case management và công cụ phản ứng. Dự án giải quyết bài toán này bằng một kiến trúc mã nguồn mở, phân tán và có khả năng mở rộng theo từng lớp.

Thách thức	Cách tiếp cận của dự án
Telemetry phân tán	Chuẩn hóa thu thập từ Windows, Linux, FIM, Sysmon, Syslog và WAF về Wazuh Manager.
Cảnh báo thiếu ngữ cảnh	Kết hợp process/network/file context với VirusTotal, AbuseIPDB và MISP.
Phân loại thủ công	Ánh xạ MITRE ATT&CK, AI narrative và incident schema có cấu trúc.
Phản ứng chậm	Telegram escalation, nút Approve/Reject và Wazuh Active Response.
Thiếu quản lý vòng đời sự cố	TheHive case management kết hợp Cortex analyzer.
Threat hunting khó tiếp cận	Dashboard/Discover và nguyên mẫu NL2Query qua Telegram.

1.2. Mục tiêu dự án

Xây dựng kiến trúc Wazuh Distributed tách biệt chức năng tiếp nhận – phân tích, lưu trữ – truy vấn và trực quan hóa.

Thu thập telemetry endpoint và ứng dụng đủ chi tiết để phát hiện các hành vi phổ biến trên Windows, Linux và web.

Phát triển decoder/rule tùy chỉnh, correlation và mapping MITRE ATT&CK phục vụ điều tra theo hành vi.

Tích hợp MISP, VirusTotal, AbuseIPDB, TheHive và Cortex để mở rộng bối cảnh, quản lý case và chia sẻ IOC.

Tạo luồng cảnh báo, phê duyệt và phản ứng tự động thông qua Telegram và Wazuh Active Response.

Thử nghiệm AI cho enrichment, incident report, ChatOps và truy vấn ngôn ngữ tự nhiên, đồng thời đánh giá khách quan giới hạn của mô hình.

Đóng gói cấu hình, mã nguồn, tài liệu vận hành, playbook và danh sách hành động bàn giao.

1.3. Phạm vi đề tài

Phạm vi
Wazuh Manager/Indexer/Dashboard phân tán
Windows/Linux agent, Sysmon, Sysmon for Linux, FIM
Juice Shop + ModSecurity CRS 3.3
MISP, VirusTotal, AbuseIPDB, TheHive, Cortex
Telegram alert, Approve/Reject, Active Response
AI enrichment, incident report, nguyên mẫu NL2Query
Purple/Red Team trong lab

1.4. Sản phẩm của đề tài

Repository kỹ thuật: cấu hình Manager/Indexer/Dashboard, decoder, rule, agent, tích hợp TI, SOAR, AI/ChatOps và Active Response.

Tài liệu kiến trúc: sơ đồ hệ thống, IP plan, mô tả luồng dữ liệu, port matrix và baseline tài nguyên.

Tài liệu vận hành: dashboard, quy trình SOC, incident response playbook và demo flow.

Tài liệu kiểm thử: kịch bản pentest/Purple Team, các chỉ số ghi nhận và danh sách gap.

Tài liệu chứng minh: quá trình và kết quả từng task của từng thành viên.

Tài liệu bàn giao này: tổng hợp trạng thái cuối, rủi ro, điểm chưa hoàn thiện và lộ trình phát triển.

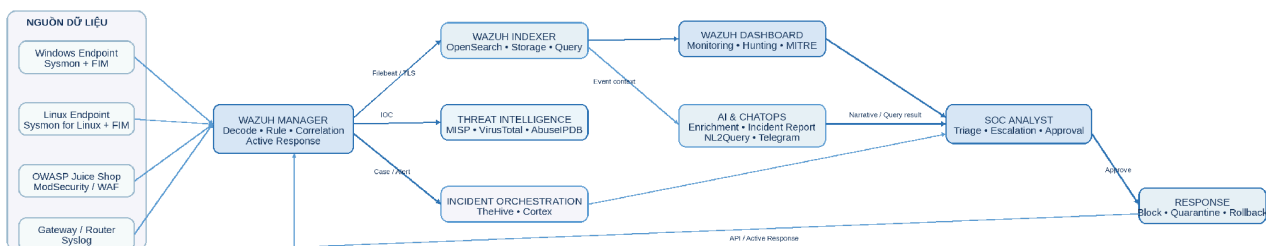
1.5. Nguyên tắc thiết kế

Nguyên tắc	Biểu hiện trong kiến trúc
Distribution	Manager, Indexer, Dashboard và SOAR/TI được tách thành các node độc lập.
Defense in Depth	WAF, endpoint telemetry, SIEM correlation, TI và response tạo thành nhiều lớp kiểm soát.
Human-in-the-loop	Hành động nhạy cảm có cơ chế Approve/Reject; auto-mode chỉ phù hợp với ngưỡng đã định nghĩa.
Traceability	Rule ID, incident ID, MITRE ID, timeline và case history hỗ trợ truy vết.
Fail-safe	AI output có JSON schema, post-processing, retry và fallback; lỗi AI không được làm mất log.
Reproducibility	Cấu hình và script được lưu trong repository; tài liệu nêu rõ các mục cần đồng bộ trước production.

2. KIẾN TRÚC VÀ LUỒNG DỮ LIỆU

2.1. Kiến trúc tổng thể

Nền tảng sử dụng Wazuh Manager làm điểm xử lý trung tâm. Endpoint và nguồn log gửi dữ liệu về Manager; các decoder và rule chuyển raw event thành alert có cấu trúc; Filebeat chuyển alert qua TLS đến Wazuh Indexer; Dashboard truy vấn Indexer để hiển thị. Các tích hợp TI/SOAR/AI hoạt động song song, nhận alert hoặc context từ Manager/Indexer và cung cấp kết quả trở lại cho analyst hoặc cơ chế phản ứng.



Hình 2. Kiến trúc logic của nền tảng SIEM/SOC tại thời điểm bàn giao.

2.2. Quy hoạch node và địa chỉ IP

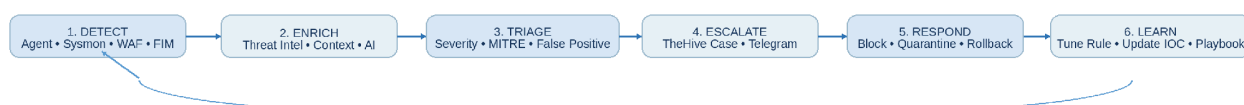
Thành phần	Địa chỉ IP	Vai trò chính
Wazuh Indexer	192.168.0.10	OpenSearch, lưu trữ và query alert
Wazuh Manager	192.168.0.11	Ingestion, decode, rule engine, API, Active Response
Wazuh Dashboard	192.168.0.12	Giao diện SOC, Discover, visualization
MISP	192.168.0.14	Threat Intelligence Platform, IOC feed
TheHive / Cortex	192.168.0.15	Case management và analyzer
OWASP Juice Shop	192.168.0.99	Web target, ModSecurity/WAF
Linux Endpoint	192.168.0.141	Wazuh Agent, Sysmon for Linux, FIM/audit telemetry
Windows Endpoint	192.168.0.171	Wazuh Agent, Sysmon, FIM

2.3. Mô hình mạng và kết nối

Mô hình cuối chuyển sang router vật lý kết hợp Bridge Mode cho máy ảo, loại bỏ phụ thuộc vào mạng overlay ZeroTier. Các VM nhận địa chỉ cùng dải LAN với máy thật, giúp giảm độ phức tạp định tuyến và mô phỏng sát cách triển khai on-premise. Kết quả kiểm tra trong lab ghi nhận độ trễ nội bộ dưới 1 ms.

Luồng	Giao thức/Port	Mục đích	Kiểm soát
Agent → Manager	TCP/UDP 1514	Gửi event và alert data	UFW/iptables giới hạn nguồn; agent authentication.
Thiết bị mạng → Manager	UDP 514	Syslog gateway/router	Chỉ mở trong LAN nội bộ.
Dashboard/scripts → Manager	TCP 55000	Wazuh REST API	TLS và credential quản trị.
Manager/Filebeat → Indexer	HTTPS 9200	Gửi và truy vấn dữ liệu	Self-signed CA của Wazuh.
Indexer internal	TCP 9300	Cluster transport	Chỉ cho mạng nội bộ; single-node hiện tại.
Client → Dashboard	HTTPS 443	Giao diện SOC	TLS; tài khoản phân quyền.
Client → Cortex	TCP 9001	Cortex Web UI/API	Giới hạn nguồn truy cập.
Quản trị → Nodes	TCP 22	SSH administration	Nên giới hạn bastion/admin subnet.

2.4. Luồng xử lý dữ liệu



Hình 3. Chu trình phát hiện – điều tra – phản ứng – cải tiến.

2.4.1. Log-to-Alert

1. Endpoint hoặc nguồn web/network phát sinh sự kiện.
2. Wazuh Agent hoặc Syslog chuyển dữ liệu đến Manager.
3. Pre-decoder tách metadata; decoder tùy chỉnh trích xuất field.
4. Rule engine thực hiện matching, correlation và MITRE mapping.
5. Alert JSON được ghi cục bộ và chuyển qua Filebeat đến Indexer.
6. Dashboard/Discover hiển thị, truy vấn và drill-down cho analyst.

2.4.2. Alert-to-Incident

1. Alert đủ điều kiện được làm giàu bằng IOC reputation và event context.
2. AI hoặc rule-based middleware tạo narrative, severity, IOC, MITRE và recommended actions.
3. Alert/case được chuyển sang TheHive; observable có thể gửi Cortex analyzer.
4. Telegram gửi thông báo 4-block và nút Approve/Reject.

5. Nếu được phê duyệt, backend gọi Wazuh API/Active Response để block hoặc quarantine.
6. Case, incident report và lịch sử xử lý được cập nhật để phục vụ hậu kiểm.

2.5. Baseline tài nguyên

Node	RAM	Disk	Ghi chú
Wazuh Manager	8 GB	100 GB	Tách khỏi Indexer để ổn định ingestion/rule engine.
Wazuh Indexer	8 GB	100 GB	Tầng lưu trữ và query; theo dõi heap và disk watermark.
Wazuh Dashboard	8 GB	100 GB	UI/visualization; có thể tối ưu nếu tách khỏi node khác.
TheHive / Cortex	12 GB	65 GB	Cụm phụ trợ cần theo dõi Java heap và analyzer workload.
MISP	4 GB	50 GB	IOC database và feed synchronization.

2.6. TLS, firewall và boundary

Chứng chỉ self-signed do bộ cài Wazuh tạo ra được dùng làm root CA cho các kết nối nội bộ. Bộ certificate được sao chép để bảo vệ giao tiếp với các thành phần liên quan. UFW/iptables được bật và chỉ mở các cổng cần thiết theo vai trò node. Đây là baseline phù hợp với lab, nhưng khi đưa vào doanh nghiệp cần cấp lại certificate theo CA nội bộ, tách network zone và triển khai quản lý secrets tập trung.

Không tắt kiểm tra TLS trong code production; loại bỏ verify=False trừ trường hợp lab có kiểm soát.

Không dùng chung tài khoản quản trị giữa Dashboard, Indexer, TheHive, Cortex và MISP.

Giới hạn API Wazuh/Indexer theo IP nguồn và role; không expose trực tiếp ra Internet.

Đưa Telegram webhook/API ra lớp integration gateway hoặc proxy nếu cần Internet egress.

Ghi nhận audit log của mọi hành động Approve/Reject và Active Response.

3. NỀN TẢNG VÀ BASELINE TRIỂN KHAI

3.1. Wazuh Manager

Manager là trung tâm ingestion và detection. Repository chứa ossec.conf, local_decoder.xml và local_rules.xml. Các daemon được xác nhận hoạt động ổn định và không còn duy trì chế độ debug/verbose không cần thiết. FIM bật query/whodata theo cấu hình phù hợp và chưa ghi nhận ảnh hưởng CPU đáng kể trong lab.

Hạng mục	Baseline
Chức năng	Agent communication, decode, correlation, alert generation, API và Active Response.
Cổng chính	1514 TCP/UDP, 514 UDP, 55000 TCP.
Cấu hình	manager/ossec.conf
Decoder	manager/decoders/local_decoder.xml
Rule	manager/rules/local_rules.xml
Log quan trọng	/var/ossec/logs/ossec.log, alerts/alerts.json, active-responses.log
Kiểm thử	/var/ossec/bin/wazuh-logtest; systemctl status wazuh-manager

3.2. Wazuh Indexer / OpenSearch

Indexer chạy chế độ single-node với 1 primary shard và 0 replica. Thiết kế này tránh trạng thái yellow do unassigned replica trong lab, nhưng không có khả năng chịu lỗi node. Hệ thống sử dụng các index chính wazuh-alerts-*, wazuh-monitoring-* và wazuh-statistics-*.

Hạng mục	Thiết kế
Shard/Replica	1 primary shard / 0 replica
Rotation	Daily rollover cho alert index
Retention	Có custom delete phase; thời hạn 30 hay 90 ngày chưa được chốt rõ trong nguồn và phải xác minh trên cluster.
GeoIP	OpenSearch ingest pipeline geoip-info, dùng GeoLite2 .mmdb cục bộ.
Geo fields	GeoLocation.country_name, city_name, continent_name, location.lat/lon.
Giới hạn	Single point of failure; static GeoIP database; chưa có automated geoipupdate.

```
curl -k -u <user>:<password> https://192.168.0.10:9200/_cluster/health?pretty
curl -k -u <user>:<password> https://192.168.0.10:9200/_cat/indices?v
curl -k -u <user>:<password> https://192.168.0.10:9200/_plugins/_ism/policies
```

3.3. Wazuh Dashboard

Dashboard cung cấp Security Events, Discover, Agent Management, MITRE view và các visualization tùy chỉnh. Dashboard Endpoint được ghi nhận hoàn thành; Dashboard Tổng quan có hướng dẫn cấu hình; Dashboard Network vẫn đang được thiết kế/tinh chỉnh một số panel. Dự án sử dụng visualization tích hợp sẵn thay vì custom Vega trong baseline cuối.

Khu vực	Ghi chú
Tổng quan	Hiển thị alert volume, severity, agent và trend.
Endpoint	Bao phủ Alert, FIM, Sysmon và Syslog.
Network	Cần hoàn thiện split rows/field mapping và nghiệm thu panel.
MITRE	Kế thừa Wazuh Security Events, Data Table và Bar Chart.
Geographic Map	Dùng Coordinate Map/Geohash và GeoLocation.location.

3.4. Endpoint telemetry

3.4.1. Windows

Windows endpoint sử dụng Wazuh Agent, Sysmon và FIM. Telemetry trọng yếu gồm process creation, network connection, CreateRemoteThread, ProcessAccess, file creation, registry modification và DNS query. Cấu hình có cơ chế loại trừ một số Event ID để giảm nhiễu.

Nguồn	Sự kiện tiêu biểu	Mục tiêu phát hiện
Sysmon Event 1	Process Create	Command line, parent-child, LOLBins, malware execution.
Sysmon Event 3	Network Connection	C2, lateral movement, suspicious outbound.
Sysmon Event 8	CreateRemoteThread	Process injection.
Sysmon Event 10	Process Access	Credential dumping/LSASS access.
Sysmon Event 11	File Create	Payload drop, persistence artifact.
Sysmon Event 13	Registry Set	Run/RunOnce persistence.
Sysmon Event 22	DNS Query	Suspicious domain/DNS C2.

3.4.2. Linux

Linux endpoint sử dụng Wazuh Agent, Sysmon for Linux và FIM; auditd được dùng như nguồn bổ sung thay vì viết decoder/rule tùy chỉnh riêng cho auditd. Repository chứa decoder Sysmon for Linux với nhiều child entry để trích xuất system và eventdata fields.

Nguồn	Sự kiện tiêu biểu	Mục tiêu
Sysmon for Linux Event 1	Process creation	Theo dõi executable, command line, parent process.
Event 3	Network connection	Outbound connection, C2, lateral movement.
Event 5	Process terminated	Vòng đời process.
Event 11	FileCreate	Payload/artifact tạo mới.
Event 16	Config state changed	Impair defenses / thay đổi Sysmon.
Event 23	FileDelete	Xóa dấu vết và data destruction.
FIM	/etc và path quan trọng	Thay đổi cấu hình hệ thống.

3.5. Web target và WAF

OWASP Juice Shop được triển khai bằng Docker trên cổng 3000 và đặt sau ModSecurity sử dụng OWASP Core Rule Set 3.3. WAF xử lý các mẫu SQL Injection, XSS, path traversal/LFI và các lỗi web phổ biến. Một số custom rule dùng để whitelist máy scan/quản trị hoặc giảm false positive. Cơ chế này tạo defense-in-depth: WAF kiểm soát request, Wazuh tiếp tục phân tích audit/access log để giám sát và điều tra.

3.6. TheHive, Cortex và MISP

Thành phần	Baseline	Lưu ý bàn giao
TheHive	Đã downgrade về 4.1.24-1 và được ghi nhận hoạt động ổn định.	Cần xác nhận package/version thực tế và backup database trước nâng cấp.
Cortex	Nguồn câu hỏi ghi 5.7.3-1.	Chuỗi version có khả năng cần kiểm tra lại bằng package manager/API vì không đồng nhất với cách đánh phiên bản thông thường.
MISP	Đồng bộ community threat feed; pull 15 phút/lần.	Version không được ghi rõ trong nguồn; phải bổ sung vào CMDB.

Thành phần	Baseline	Lưu ý bàn giao
Tích hợp	MISP hai chiều; TheHive/Cortex dùng observable/analyzer.	Kiểm tra API key, permission, dedup và certificate.

3.7. Baseline phiên bản

Thành phần	Phiên bản/nguồn ghi nhận
Wazuh core	Repository README khai báo v4.14.5
OpenSearch	2.x
TheHive	4.1.24-1
Cortex	5.7.3-1 theo bộ câu hỏi
MISP	Không ghi nhận
OWASP CRS	3.3
Python	3.10+
AI local	Llama 3.1 8B qua Ollama
AI cloud	Gemini client có trong repository

4. DETECTION ENGINEERING VÀ MITRE ATT&CK

4.1. Decoder

Repository snapshot chứa 60 decoder entry. Phần lớn là child decoder của Sysmon for Linux nhằm trích xuất các trường system/eventdata; ngoài ra có decoder family cho Juice Shop access log. Cách đếm “entry” khác với số “decoder family”, vì một parent decoder có nhiều child regex.

Decoder family	Field tiêu biểu	Mục đích
Sysmon for Linux	system.eventId, processGuid, image, commandLine, source/destination IP/port, targetFilename, hashes	Chuẩn hóa telemetry Linux theo cấu trúc Sysmon.
Juice Shop	method, url, status, size, referer	Phát hiện SQLi, XSS, traversal và HTTP error từ web access log.
auditd	Dùng rule/decoder mặc định của Wazuh	Tránh side effect và trùng lặp custom parser; bổ sung Sysmon for Linux.

4.2. Custom rule và correlation

local_rules.xml trong snapshot có 41 rule entry, bao phủ Windows Sysmon, Linux Sysmon, SSH/authentication, MISP IOC và Juice Shop. Một số rule có level thấp để tạo base event hoặc tuning, trong khi IOC/hash và credential access có level cao hơn. Correlation SSH dùng frequency 5; timeframe có sự khác biệt giữa bộ câu hỏi và repository, được ghi nhận trong mục gap.

Nhóm	Rule ID tiêu biểu	Mức độ / hành vi
Windows detection	100001, 100002, 100030, 100031, 100041, 100050, 100070	Suspicious execution, credential dumping, process injection, registry persistence, lateral movement, exfiltration.
Authentication	100250, 100512	Local/SSH brute force.
Linux Sysmon	200150–200157	Process, network, file, config change và file deletion.
Threat Intelligence	100901, 100903, 100910, 100920, 100922	IOC IP/domain/hash match từ MISP/CDB.
Web	100300–100306	Base access, SQLi, XSS, traversal/LFI, HTTP error.

Nhóm	Rule ID tiêu biểu	Mức độ / hành vi
Tuning	100200–100202, 200200–200202	Whitelist/giảm noise cho hoạt động quản trị và agent.

4.3. MITRE ATT&CK coverage

Bộ câu hỏi chốt 21 Technique ID thuộc 11 Tactic của MITRE ATT&CK Enterprise. Rule 100041 ánh xạ nhiều kỹ thuật cho lateral movement/execution; các rule khác bao phủ persistence, process injection, credential access, DNS/C2, exfiltration, initial access và impact. Việc mapping giúp dashboard và incident report sử dụng chung ngôn ngữ hành vi.

Tactic	Technique tiêu biểu
Initial Access	T1190
Execution	T1047, T1059, T1204, T1569.002
Persistence	T1044, T1547.001
Privilege Escalation	T1044, T1055, T1547.001
Defense Evasion	T1055, T1107, T1562
Credential Access	T1003, T1110
Discovery	T1083
Lateral Movement	T1021.002, T1047
Command and Control	T1043, T1071, T1071.004, T1105
Exfiltration	T1020, T1048
Impact	T1485

4.4. False positive và tuning

False positive rate cuối kỳ được ghi nhận 15–20%. Kết quả này tốt hơn ngưỡng ban đầu dưới 30% nhưng chưa đạt mục tiêu dưới 10%. Nguyên nhân gồm alert trùng, rule web/endpoint có độ rộng cao, hoạt động quản trị giống hành vi tấn công và thiếu bộ test set cố định. Tuning hiện có whitelist nội bộ và rule level 0/1 cho noise, nhưng cần quy trình đo lường có kiểm soát hơn.

Vấn đề	Ảnh hưởng	Hướng xử lý
Duplicate alert/TheHive case	Tăng tải triage và sai số metric.	Chuẩn hóa sourceRef/dedup key theo rule ID + agent + IOC + time bucket; test idempotency.
SSH brute force FPR 15–20%	Có thể chặn nhầm hoạt động hợp lệ.	Tách private/public source, account risk, allowlist và adaptive threshold.

Vấn đề	Ảnh hưởng	Hướng xử lý
Noise từ agent/system	Tăng alert volume.	Tiếp tục tuning 200200–200202 và kiểm tra không che khuất true positive.
Web rule rộng	False positive ở request hợp lệ.	Dùng WAF anomaly score, parameter context và negative test.
Không có fixed test set	Metric khó tái lập.	Xây test corpus 50–100 alert có nhãn và regression test tự động.

4.5. Nguyên tắc nghiệm thu rule

1. Có ít nhất một positive case và một negative case trong wazuh-logtest.
2. Field decoder khớp mapping thực tế trên OpenSearch/Discover.
3. Rule level, MITRE ID và description phản ánh đúng hành vi.
4. Correlation có test boundary cho frequency/timeframe.
5. Không tạo duplicate case hoặc Active Response lặp.
6. Không làm tăng FPR vượt ngưỡng đã phê duyệt.
7. Có rollback/disable plan nếu rule gây side effect.

4.6. Detection quality gate tại thời điểm bàn giao

Hạng mục	Đánh giá	Điều kiện để đóng
Decoder coverage	Đạt cho nguồn chính	Bổ sung regression case cho format biến thể.
MITRE mapping	Có baseline 21 technique	Review legacy ID và cập nhật evidence.
False positive	Chưa đạt mục tiêu	Giảm từ 15–20% xuống dưới 10% trên fixed test set.
Correlation/dedup	Còn khác biệt	Chốt timeframe 100512 và loại bỏ duplicate action/case.

5. THREAT INTELLIGENCE, CASE MANAGEMENT VÀ PHẢN ỨNG

5.1. MISP và CDB List

MISP đồng bộ threat feed community và cung cấp IOC cho Wazuh thông qua CDB List. Job pull được cấu hình theo chu kỳ 15 phút. Bộ câu hỏi ghi nhận 1.904 IOC và đã kiểm thử thành công với IP nằm trong CDB để sinh alert. Luồng tích hợp được mô tả là hai chiều: Wazuh tiêu thụ IOC và incident có thể cung cấp IOC trở lại MISP.

Loại IOC	Rule tiêu biểu	Hành vi
IP Windows outbound	100901	Sysmon kết nối tới blocklisted IP.
IP Linux outbound	100903	Sysmon for Linux kết nối tới blocklisted IP.
Domain	100910	DNS query tới blocklisted domain.
FIM hash	100920	File integrity event chứa blocklisted hash.
Process hash	100922	Process image có hash nằm trong blocklist.

5.2. VirusTotal và AbuseIPDB

VirusTotal được dùng cho file hash, AbuseIPDB cho IP reputation. Trong quá trình test nội bộ, lưu lượng dưới 5 request/ngày và chưa chạm rate limit free tier. Middleware đã tính đến HTTP 429/retry. Khi mở rộng số agent, phải có cache, dedup và quota monitoring để tránh gọi lặp cho cùng IOC.

Cache kết quả IOC theo TTL phù hợp với loại dữ liệu.

Không gửi dữ liệu nhạy cảm hoặc file nội bộ lên dịch vụ cloud nếu chưa có phê duyệt.

Tách API key theo môi trường dev/test/prod và quản lý bằng secret manager.

Ghi log request count, latency, status code và quota remaining nếu API hỗ trợ.

5.3. TheHive/Cortex workflow

TheHive tiếp nhận alert/case, lưu incident history và hỗ trợ giao việc/leo thang.

Cortex phân tích observable bằng analyzer. Sau khi downgrade TheHive về

4.1.24-1, integration được ghi nhận hoạt động ổn định. Vấn đề duplicate đã được giảm bằng sourceRef dedup nhưng chưa loại bỏ hoàn toàn ở mọi rule.

Bước	Kết quả mong đợi	Kiểm soát
Create alert/case	Có sourceRef duy nhất, severity, tags, agent và incident ID.	Idempotency và retry không tạo bản sao.
Add observable	IP, domain, hash hoặc URL được gắn vào case.	Validate type, dedup observable.
Run analyzer	Kết quả reputation/context được trả về.	Timeout, quota, error handling.
Escalate	Assign/notes/status theo SOC workflow.	SLA và audit trail.
Close/resolve	Kết luận và action được ghi nhận.	Không xóa evidence; cập nhật IOC nếu phù hợp.

5.4. Active Response và human-in-the-loop

Backend Telegram nhận callback approve_<incident_id> hoặc reject_<incident_id>. Khi được phê duyệt, backend lấy token Wazuh, gọi Active Response và cập nhật incident report. Một số luồng có auto-rollback, giúp giảm rủi ro block kéo dài. Đây là cơ chế phù hợp với lab và SOC vận hành có kiểm soát, nhưng cần RBAC, MFA và audit nếu đưa vào production.

```
Alert → Telegram 4-Block → Approve/Reject callback
Approve → Wazuh API / Active Response → block/quarantine
Timer / policy → rollback → update Telegram + incident report
```

5.5. Incident report schema

Schema 10 field được chốt và có post-processing để thay null bằng chuỗi “N/A” hoặc mảng rỗng. Middleware có retry/fallback; trong đợt pentest không ghi nhận bot crash hay mất log do JSON malformed.

Field	Mô tả
incident_id	Mã định danh duy nhất cho sự cố.
severity	Mức độ nghiêm trọng.
patient_zero	Endpoint hoặc tài sản bị ảnh hưởng đầu tiên.
affected_user	Tài khoản/người dùng liên quan.
attack_summary	Tóm tắt chuỗi hành vi.
ioc	Danh sách IP, domain, hash, URL.
threat_verdict	Kết luận TI/AI và độ tin cậy nếu có.
mitre_techniques	Technique ID liên quan.
timeline	Các mốc sự kiện chính.
recommended_actions	Hành động ưu tiên và điều kiện phê duyệt.

6. AI, CHATOPS VÀ NL2QUERY

6.1. Kiến trúc AI

Dự án bắt đầu với Llama 3.1 8B chạy qua Ollama local nhằm giữ dữ liệu trong mạng nội bộ. Baseline latency 20–30 giây/request do inference CPU-only. Repository mới có gemini_client.py và ChatOps code chuyển một số tác vụ sang Gemini API để cải thiện chất lượng JSON và thời gian xử lý. Do nguồn tài liệu ghi nhận các giai đoạn khác nhau, trạng thái bàn giao nên được hiểu là kiến trúc hybrid/đang chuyển đổi, không phải một benchmark cloud hoàn chỉnh.

Lớp	Vai trò	Rủi ro/kiểm soát
Prompt contract	Ràng buộc task, field, output JSON.	Version prompt, regression test.
LLM local/cloud	Sinh narrative, IR hoặc điều kiện truy vấn.	Data policy, latency, quota, model drift.
Post-processing	Chuẩn hóa null, kiểu dữ liệu và default.	Không biến lỗi semantic thành kết quả “hợp lệ” giả.
Validator	JSON schema, DSL validation, field whitelist.	Validate với OpenSearch trước khi chạy.
Fallback	Rule-based/static output khi AI lỗi.	Không làm mất alert hoặc chặn luồng SOC.
Audit	Log prompt version, model, latency, usage.	Ẩn secrets và dữ liệu nhạy cảm.

6.2. Trạng thái các tính năng AI

Tính năng	Trạng thái	Kết quả/giới hạn
Alert Enrichment	Operational có kiểm soát	Phân loại severity, narrative, IOC và MITRE; cần kiểm tra hallucination.
Threat Intel Summarization	Operational	Tóm tắt kết quả TI; phụ thuộc chất lượng API và cache.
Incident Report 10 field	Operational	Valid JSON được ghi nhận 100% trong đợt test; có retry/fallback.
NL2Query	Prototype end-to-end	Khoảng 60% query phù hợp; thường đúng cú pháp nhưng sai field/ý nghĩa.

Tính năng	Trạng thái	Kết quả/giới hạn
Dynamic Playbook	Chưa hoàn thiện	Có prompt/code thử nghiệm nhưng không được nghiệm thu như chức năng bàn giao.
Gap Analysis	Chưa hoàn thiện	Không có quy trình tự động đáng tin cậy để đối chiếu attack step – detection.

6.3. Chỉ số AI và giới hạn đo lường

Metric được báo cáo	Giá trị	Diễn giải thận trọng
Severity classification	92%	Kết quả sau pentest, nhưng sample size không được tách cố định.
MITRE mapping	88%	Cần bộ nhãn chuẩn và adjudication để xác nhận.
False Positive assessment	82%	Không đồng nhất với FPR tổng hệ thống; cần định nghĩa metric rõ.
Valid JSON	100%	Phản ánh độ hợp lệ cú pháp trong đợt test, không bảo đảm đúng ngữ nghĩa.
Gap Analysis	94%	Không dùng làm acceptance evidence vì tính năng Gap Analysis chưa hoàn thiện.

6.4. NL2Query qua Telegram

Luồng /query đã triển khai end-to-end: câu hỏi tiếng Việt → AI/IR → OpenSearch DSL → query Indexer → trả kết quả Telegram. Vấn đề chính là field hallucination và sai ý nghĩa truy vấn dù JSON/DSL hợp lệ. Repository hiện chứa các biện pháp kỹ thuật như field reference, live mapping fetch, field repair, enum-constrained schema, IR phẳng và _validate/query. Tuy nhiên bộ câu hỏi chốt độ chính xác khoảng 60%, vì vậy đây vẫn là công cụ hỗ trợ, không phải nguồn kết luận duy nhất.

Kiểm soát cần có	Mục đích
Intent classification	Không chuyển câu hỏi health-check hoặc ngoài phạm vi thành alert search.
Live mapping + static fallback	Chỉ cho phép field thật tồn tại trong index.
Intermediate Representation	AI sinh điều kiện phẳng; code deterministic biên dịch sang DSL.
OpenSearch validate API	Phát hiện lỗi cú pháp trước khi chạy.
Semantic guardrail	Kiểm tra query không bị rỗng hoặc mất nội dung sau repair.

Kiểm soát cần có	Mục đích
Confirmation step	Hiển thị câu hỏi, DSL tóm tắt và phạm vi thời gian trước khi analyst thực thi.
Golden query set	Đo precision/recall trên bộ câu hỏi chuẩn có kết quả kỳ vọng.

6.5. Data governance cho AI

Phân loại dữ liệu được phép gửi lên cloud; loại bỏ credential, PII và nội dung file nhạy cảm.

Ghi nhận model/version, prompt version, token usage và latency cho mỗi request.

Thiết lập timeout, retry có backoff, circuit breaker và quota budget.

Không cho LLM quyết định trực tiếp hành động phá hủy hoặc block lâu dài.

Lưu output AI như “advisory evidence”, phân biệt với dữ liệu telemetry gốc.

Kiểm tra điều khoản lưu trữ dữ liệu của nhà cung cấp trước khi triển khai doanh nghiệp.

7. DASHBOARD, SOC WORKFLOW VÀ PLAYBOOK

7.1. Dashboard phục vụ vận hành

Dashboard được thiết kế theo ba góc nhìn: tổng quan, endpoint và network. Analyst sử dụng auto-refresh, time range, filter theo agent/rule/severity/MITRE và drill-down sang Discover. Geographic field và MITRE mapping giúp chuyển từ số lượng alert sang bối cảnh nguồn, tài sản và hành vi.

Câu hỏi vận hành	Panel/Field cần dùng
Có bao nhiêu alert High/Critical trong ca?	rule.level, @timestamp, agent.name.
Tài sản nào bị ảnh hưởng nhiều nhất?	agent.name / agent.id aggregation.
Kỹ thuật tấn công nào nổi bật?	rule.mitre.id và rule.mitre.tactic.
Nguồn IP nào đáng chú ý?	data.srcip / win.eventdata.destinationIp / GeoLocation.
Có thay đổi file bất thường?	syscheck.path, syscheck.event, hash fields.
Có chuỗi process nghi vấn?	processGuid, parentProcessGuid, image, commandLine.

7.2. Quy trình SOC L1–L2–L3

Quy trình vận hành dùng TheHive làm kênh quản lý case chính và Telegram làm kênh cảnh báo/escalation nhanh. L1 giám sát và triage, L2 điều tra sâu và xác minh IOC/context, L3 xử lý kỹ thuật phức tạp hoặc điều chỉnh detection/response. SLA cần được cấu hình theo severity và môi trường doanh nghiệp.

Cấp	Trách nhiệm chính
L1	Giám sát, xác nhận alert, thu thập field, mở/assign case, escalate.
L2	Correlation, TI lookup, timeline, containment recommendation.
L3	Forensic sâu, rule tuning, recovery, root cause và cải tiến.

7.3. Playbook

Bộ câu hỏi mô tả Playbook v2.0 với 16 playbook, bao gồm các tình huống endpoint, web, network và cloud. Tuy nhiên repository hiện chứa tài liệu v1.0 với 10 playbook. Các playbook được xác nhận trong file v1 gồm brute force, malware, privilege escalation, lateral movement, data exfiltration, web attack, suspicious process, FIM,

network anomaly/port scan và insider threat. Bản v2 cần được bổ sung hoặc đồng bộ vào repository trước khi coi là artifact bàn giao hoàn chỉnh.

Playbook domain	Ví dụ hành vi
Authentication	Brute force / đăng nhập thất bại hàng loạt.
Malware	Hash/behavior match, quarantine và IOC enrichment.
Privilege & persistence	Registry Run/RunOnce, process injection, scheduled mechanisms.
Lateral movement	SMB/PsExec/WMI và remote execution.
Exfiltration	Ngrok, DNS, script engine network activity.
Web	SQLi, XSS, path traversal/LFI và WAF event.
Integrity	File creation/deletion và FIM violation.
Network	Port scan, anomalous traffic, suspicious IP/domain.
Cloud mở rộng	Misconfiguration, IAM abuse theo mô tả v2; chưa có artifact đầy đủ trong repository.

7.4. Demo flow

1. Red Team phát sinh brute-force, malware hoặc web attack trong lab; Dashboard bật auto-refresh.
2. SOC analyst phát hiện alert High/Critical và drill-down các field agent, source IP, process/file và MITRE.
3. Threat Intelligence và AI enrichment bổ sung reputation, narrative và confidence/context.
4. TheHive mở alert/case; observable được gửi Cortex nếu phù hợp.
5. Telegram gửi cảnh báo 4-block kèm nút tương tác.
6. Analyst phê duyệt hành động; Wazuh Active Response block/quarantine và thực hiện rollback theo policy.

7.5. Lịch vận hành đề xuất

Tần suất	Hoạt động
Mỗi ca / Hàng ngày	Kiểm tra cluster health, agent status, alert backlog, failed integrations, TheHive queue và disk watermark.
Hàng tuần	Review FP/TP, duplicate case, IOC sync, failed analyzer, API quota, backup success và rule change.
Hàng tháng	Patch review, certificate expiry, retention/disk trend, role/account review, playbook drill và restore test.
Hàng quý	Purple Team regression, MITRE coverage review, secret rotation, capacity planning và DR tabletop.

8. KIỂM THỬ VÀ ĐÁNH GIÁ

8.1. Phương pháp kiểm thử

Việc kiểm thử được thực hiện trong lab với các kịch bản đại diện thay vì một chiến dịch pentest production. Nguồn báo cáo pentest mô tả các phase reconnaissance/network scan, brute force SSH, execution bằng LOLBins/obfuscated command, persistence, defense evasion và sensitive file access. Web attack được kiểm thử riêng qua Juice Shop/WAF và một số luồng endpoint được kiểm thử qua Sysmon/FIM.

8.2. Kết quả SOC drill

Chỉ số	Kết quả	Nhận xét
Alert hits	12.527	Phản ánh tải log/cảnh báo cao trong khoảng kiểm thử; có noise và lặp.
True Positive triage	5 sự cố tiêu biểu	Brute force và FIM được phân loại đúng theo ghi nhận.
MTTD/Triage	Dưới 5 phút	Từ log thô đến đối chiếu MITRE và quyết định escalate.
Incident fields	Patient zero, attacker IP, MITRE, top actions	Đủ cho biên bản sự cố cơ bản.
Active Response	Đã minh họa block/rollback	Cần kiểm soát allowlist và quyền phê duyệt.

8.3. Kết quả kỹ thuật

Năng lực	Kết quả	Điểm còn thiếu
Log collection	Không ghi nhận mất alert; có lặp alert.	Theo dõi queue/backpressure bằng metric định lượng.
Decoder	Juice Shop và Sysmon for Linux trích xuất field quan trọng.	Tăng regression test cho format biến thể.
Rule/MITRE	41 rule entry; 21 technique / 11 tactic.	FPR 15–20%, một số mapping cần review.
MISP	1.904 IOC, test match thành công.	Đo sync failure, stale IOC và feed quality.
TheHive	Hoạt động sau downgrade.	Duplicate chưa hết; artifact version chưa đồng bộ.

Năng lực	Kết quả	Điểm còn thiếu
AI report	JSON ổn định trong đợt test.	Sample size và semantic accuracy chưa đủ chuẩn.
NL2Query	End-to-end hoạt động.	Khoảng 60%, sai field/ý nghĩa; chưa production-ready.

8.4. Hiệu năng và khả năng mở rộng

Lab ghi nhận kết nối nội bộ ổn định và không có bottleneck rõ ràng trong workload thử nghiệm. AI local là điểm chậm đáng kể với latency 20–30 giây do CPU-only. Indexer single-node và 0 replica phù hợp lab nhưng là điểm nghẽn/điểm lỗi đơn khi mở rộng. Tài liệu hiện chưa có EPS peak, storage growth/day, query p95, API p95 hoặc concurrency benchmark.

Metric cần bổ sung	Cách đo đề xuất
Events per second	Wazuh statistics + Indexer ingest rate theo peak/average.
End-to-end alert latency	Timestamp source → Manager → Indexer → Telegram/TheHive.
Query latency	p50/p95/p99 cho dashboard và NL2Query golden set.
Storage growth	GB/ngày theo source và severity; dự báo retention.
Duplicate rate	Số case/alert trùng trên tổng event đủ điều kiện.
AI accuracy	Bộ test có nhãn, confusion matrix và lỗi semantic.
Response safety	Tỷ lệ approve/reject, rollback success và block nhầm.

8.5. Tiêu chí nghiệm thu đề xuất cho giai đoạn tiếp theo

Hạng mục	Ngưỡng tối thiểu đề xuất
FPR	<10% trên fixed labeled test set.
Duplicate case	<1% và idempotency pass cho retry.
NL2Query	≥90% field validity; ≥80% semantic pass trên golden set trước khi dùng vận hành.
AI JSON	100% schema validity và không mất alert khi model/API lỗi.
Indexer	Không yellow/red trong steady state; restore test pass.
Active Response	100% rollback success trong test, 0 block allowlisted asset.
Playbook	Artifact v2 đồng bộ repository và drill ít nhất một lần/playbook critical.

9. VẬN HÀNH VÀ BÀN GIAO KỸ THUẬT

9.1. Cấu trúc repository

Đường dẫn	Nội dung
manager/	ossec.conf, custom decoder và custom rule.
agents/agent-windows/	ossec.conf và sysmonconfig.xml cho Windows.
indexer/	opensearch.yml, jvm.options và cấu hình liên quan.
dashboard/	opensearch_dashboards.yml.
integrations/abuseIPDB/	Script và integration config AbuseIPDB.
integrations/virustotal/	Script và integration config VirusTotal.
integrations/soar/	TheHive, Cortex, MISP config/baseline.
integrations/artificial-intelligence/	Prompt và source cho Gemini/ChatOps/Playbook/SOAR backend.
integrations/active-response/	Quarantine, firewall block và rollback.
integrations/threat-hunting/	KQL/query playbook.
docs/	Sơ đồ, báo cáo chuyên đề và incident response playbook.

9.2. Backup và phục hồi

Bộ câu hỏi ghi nhận backup/snapshot cuối kỳ được lưu local; cấu hình/tài liệu nhẹ được lưu trên GitHub. Cách này đủ cho lab nhưng chưa phải chiến lược backup doanh nghiệp. Tài liệu bàn giao cần kèm manifest, checksum, lịch backup, retention, encryption và restore test.

Đối tượng	Nội dung cần backup
Wazuh Manager	ossec.conf, rules, decoders, CDB lists, keys, integration scripts.
Indexer	Snapshot repository, index template, ISM/ILM policy, ingest pipeline.
Dashboard	Saved objects/export, index patterns, visualization.
TheHive/Cortex	Database, config, templates, analyzer config.
MISP	Database, attachments, config, feeds, taxonomies.
AI/ChatOps	Prompt, schema, golden test set, service unit, logs không chứa secret.

9.3. Quản lý secrets

Rà soát repository cho thấy credential/API key/password/secret có thể xuất hiện trực tiếp trong nhiều tệp. Đây là phát hiện có mức độ Critical đối với hoạt động bàn giao. Không nên chỉ xóa giá trị ở commit mới vì secret vẫn tồn tại trong lịch sử Git.

1. Thu hồi và rotate toàn bộ API key, bot token, tài khoản Dashboard/Indexer, TheHive và secret Cortex/MISP đã từng được commit.
2. Xóa secret khỏi file; chuyển sang .env, systemd EnvironmentFile, Wazuh keystore hoặc secret manager.
3. Bổ sung .gitignore, file .env.example chỉ chứa placeholder.
4. Dùng git filter-repo/BFG để làm sạch lịch sử nếu repository sẽ được chia sẻ.
5. Chạy secret scanner trước mỗi release và bật pre-commit/CI gate.
6. Ghi nhận người sở hữu, ngày rotate, scope và ngày hết hạn trong secret inventory.

9.4. Quản lý thay đổi

Loại thay đổi	Quy trình tối thiểu
Decoder/Rule	Peer review → logtest → staging → canary → monitor FPR → rollout.
Prompt/AI model	Version prompt → golden test → privacy review → staged release → rollback.
Dashboard	Export saved objects trước/sau; kiểm tra field mapping.
MISP feed	Đánh giá chất lượng feed, TTL, false positive và nguồn gốc IOC.
TheHive/Cortex upgrade	Backup, compatibility matrix, migration rehearsal và rollback plan.
Certificate/credential	Change window, rotate có overlap, kiểm tra integration sau thay đổi.

10. KẾT LUẬN

Dự án đã hình thành một nền tảng SOC thu gọn có kiến trúc rõ ràng, tách lớp và bao phủ toàn bộ chu trình cơ bản từ telemetry đến response. Các thành phần Wazuh, OpenSearch, endpoint monitoring, WAF, Threat Intelligence, TheHive/Cortex, MISP, Telegram và AI được tích hợp thành một pipeline có thể trình diễn và kiểm thử end-to-end trong lab. Giá trị lớn nhất của hệ thống là tính liên kết: alert không dừng ở việc hiển thị mà được bổ sung IOC, MITRE, narrative, case management và hành động phản ứng có kiểm soát.

Tuy vậy, tài liệu bàn giao không xem hệ thống là production-ready tuyệt đối. Những vấn đề về secrets trong repository, FPR 15–20%, duplicate case, single-node Indexer, version/retention chưa chốt, NL2Query 60% và hai chức năng AI chưa hoàn thiện cần được xử lý theo lộ trình. Khi các hạng mục P0/P1 được đóng, nền tảng sẽ có cơ sở tốt để chuyển từ mô hình thực tập/lab sang môi trường thử nghiệm doanh nghiệp có quản trị.

PHỤ LỤC A. MITRE ATT&CK MAPPING

Rule ID	Level	MITRE ID	Description
100001	10	T1059	Suspicious Process Execution: \$(win.eventdata.image)
100002	12	T1003	Credential Dumping tool detected: \$(win.eventdata.image)
100004	12	T1048	Data Exfiltration: ngrok tool detected
100030	12	T1055	Privilege Escalation/Lateral Movement: Process Injection (CreateRemoteThread) detected
100031	12	T1547.001	Privilege Escalation: Persistence via Registry Run/RunOnce keys
100041	12	T1021.002, T1047, T1569.002	Suspicious Lateral Movement: Phát hiện tiến trình thực thi lệnh từ xa (Impacket PsExec/WMI detected)
100050	10	T1048	Data Exfiltration: DNS Query to suspicious domain
100070	10	T1059, T1105	Suspicious Process Execution: LOLBins (powershell, certutil, mshta) detected
100101	10	T1020	Insider Threat Alert: Massive file manipulation outside business hours!
100301	12	T1190	Juice Shop: SQL Injection attempt in URI
100302	11	T1190	Juice Shop: XSS attempt in URI
100303	10	T1083	Juice Shop: Directory Traversal / LFI attempt

Rule ID	Level	MITRE ID	Description
100305	12	T1190	Juice Shop: SQL Injection attempt in Referer
100306	11	T1190	Juice Shop: XSS attempt in Referer header
100512	10	T1110	sshd: brute force trying to get access to the system.
100901	13	T1071	MISP IOC: Sysmon outbound connection to blocklisted IP \$(win.eventdata.destinationIp)
100903	13	T1071	MISP IOC: Linux Sysmon network connection to blocklisted IP
100910	13	T1071.004	MISP IOC: DNS query for blocklisted domain \$(win.eventdata.queryName)
100920	14	T1204	MISP IOC: FIM detected blocklisted hash at \$(syscheck.path)
100922	15	T1204	MISP IOC: Process with blocklisted hash — \$(win.eventdata.image)
200150	3	T1204	Sysmon For Linux Event
200151	3	T1204	Sysmon - Event 1: Process creation \$(eventdata.image)
200152	3	T1043	Sysmon - Event 3: Network connection by \$(eventdata.image)
200153	3	T1204	Sysmon - Event 5: Process terminated \$(eventdata.image)
200154	3	T1204	Sysmon - Event 9: Raw Access Read by \$(eventdata.image)
200155	3	T1044	Sysmon - Event 11: FileCreate by \$(eventdata.image)

Rule ID	Level	MITRE ID	Description
200156	3	T1562	Sysmon - Event 16: Sysmon config state changed \$(Event.EventData.Data.Configuration)
200157	3	T1107, T1485	Sysmon - Event 23: FileDelete (A file delete was detected) by \$(eventdata.image)
200200	1	T1107, T1485	Sysmon - Event 3: Network connection by \$(eventdata.image)
200201	1	T1107, T1485	Sysmon - Event 11: FileCreate by \$(eventdata.image)
200202	1	T1107, T1485	Sysmon - Event 23: FileDelete (A file delete was detected) by \$(eventdata.image)

PHỤ LỤC B. MA TRẬN PORT VÀ DỊCH VỤ

Node/Dịch vụ	Port	Protocol	Nguồn được phép	Mục đích
Wazuh Manager	1514	TCP/UDP	Agent subnets	Agent event transport.
Wazuh Manager	514	UDP	Gateway/network devices	Syslog ingestion.
Wazuh Manager	55000	TCP/TLS	Dashboard/integration admin	Wazuh API.
Wazuh Indexer	9200	TCP/TLS	Manager, Dashboard, authorized apps	OpenSearch REST.
Wazuh Indexer	9300	TCP	Indexer nodes only	Cluster transport.
Wazuh Dashboard	443	TCP/TLS	SOC/admin networks	Web UI.
TheHive	9000 (verify)	TCP/TLS	SOC/integration	Case UI/API; port phải xác minh theo config.
Cortex	9001	TCP/TLS	TheHive/SOC	Analyzer UI/API.
MISP	443 (verify)	TCP/TLS	Wazuh/TheHive/admin	MISP UI/API.
SSH	22	TCP	Admin/bastion only	System administration.
Juice Shop	3000/internal	TCP	WAF/reverse proxy/lab	Web target.

PHỤ LỤC C. CÁC LỆNH XÁC MINH BÀN GIAO

```
# Wazuh Manager
/var/ossec/bin/wazuh-control info
/var/ossec/bin/wazuh-control status
/var/ossec/bin/wazuh-logtest

# Indexer/OpenSearch
curl -k -u <user>:<password> https://192.168.0.10:9200
curl -k -u <user>:<password> https://192.168.0.10:9200/_cluster/health?pretty
curl -k -u <user>:<password> https://192.168.0.10:9200/_cat/indices?v

# Package inventory
dpkg -l | egrep "wazuh|opensearch|thehive|cortex|misp"
systemctl --no-pager --failed

# Network
ss -lntup
ufw status numbered

# Secret scan (không in giá trị vào báo cáo)
gitleaks detect --source .
# hoặc công cụ secret scanner được doanh nghiệp phê duyệt
```